

Graded Lab IR Playbook

Solomon Mwaura

1. Identify and Categorize the Incident

Review data from monitoring tools and reports: Several employees reported a suspicious email. Investigation into network and EDR logs confirmed that one employee workstation (IP: **192.168.10.25**) successfully clicked the link, downloaded a payload, and initiated outbound communication with an external server.

Categorize the incident: This incident is categorized as a **Phishing Attack leading to a Malware Infection and Command-and-Control (C2) Compromise**. Due to the financial services environment, this is a High-Severity (P2) incident requiring immediate containment.

Indicators of Compromise (IoCs):

- **Email Sender:** **attacker@example.com**
- **Email Subject:** "Urgent Account Verification Required!"
- **Malicious URL:** **http://malicious-site.com/reset**
- **Payload Source IP:** **203.0.113.99**
- **Command and Control (C2) IP:** **198.51.100.88**
- **Malicious File:** **invoice.pdf.exe** (Note the deceptive double extension)
- **File Hash (MD5):** **7c9e3a5b6d8f12a4abc9d5678912efab**

2. Contain the Incident

Isolate affected systems from the network:

- Immediately quarantine workstation **192.168.10.25** using the EDR platform's network isolation feature. This cuts off the active C2 connection to **198.51.100.88** while keeping the machine powered on for memory forensics.
- Force a mandatory password reset for the affected employee and revoke any active session tokens.

Block malicious IPs and domains:

- Add **203.0.113.99** and **198.51.100.88** to the firewall and Secure Web Gateway blocklists.
- Block the domain **malicious-site.com** across the network.

- Update the secure email gateway (SEG) to quarantine any incoming emails from `attacker@example.com` or containing the subject line "Urgent Account Verification Required!".

3. Analyze the Threat

Investigate suspicious files and processes: The threat actor utilized a classic social engineering lure (urgency) combined with a deceptive file naming convention (`invoice.pdf.exe`). By hiding the executable extension, the user was tricked into running the malware, believing it was a PDF document. Once executed, the process initiated outbound communication to a known C2 server to await further instructions or begin data exfiltration.

Correlate findings with external threat intelligence feeds:

- Search the corporate email environment to identify all other users who received this email and permanently delete it from their inboxes.
- Query the MD5 hash (`7c9e3a5b6d8f12a4abc9d5678912efab`) and C2 IP against platforms like VirusTotal or internal threat intelligence platforms (TIP) to identify the specific malware family (e.g., Emotet, Trickbot) and understand its typical post-compromise behaviors.

4. Eradicate the Threat

Remove malicious files and secure affected systems:

- Given the financial sector's strict security requirements, the safest method of eradication is to completely wipe and reimage workstation `192.168.10.25` from a known clean golden image.
- If reimaging is not immediately possible, use the EDR tool to kill the `invoice.pdf.exe` process, delete the file, and remove any persistence mechanisms (e.g., registry run keys, scheduled tasks) created by the malware.

Patch vulnerabilities and apply configuration updates:

- The primary vulnerability was human error combined with permissive email filtering.
- Configure the operating system to "Always show file extensions" globally via Group Policy Object (GPO) so users can easily spot double extensions like `.pdf.exe`.

5. Recover and Restore Operations

Verify systems are clean and operational:

- After reimaging the workstation, ensure the latest OS patches, EDR agents, and anti-virus signatures are installed and fully updated.

- Perform a full offline scan of any user files restored from backups before placing them back on the clean machine.

Reconnect systems to the network after testing:

- Reconnect the workstation to the corporate network.
- Place the user's machine in a highly monitored group within the SIEM/EDR for the next 72 hours to ensure no residual C2 traffic or anomalous behavior occurs.

6. Post-Incident Review and Reporting

Document the incident and all actions taken: An employee was targeted by a phishing email, resulting in the download and execution of a malicious payload (`invoice.pdf.exe`). The system successfully connected to a C2 server before being isolated by the IR team. The threat was contained via EDR isolation, eradicated via system reimaging, and network blocks were applied to the identified IoCs.

Identify process gaps and recommend updates:

- **Gap 1:** The Secure Email Gateway (SEG) failed to strip or quarantine an executable file disguised as a PDF.
- **Gap 2:** The employee fell for the phishing lure, indicating a lapse in security awareness.
- **Gap 3:** Windows default settings hid the `.exe` extension, enabling the deception.

7. Proactive Monitoring and Preventative Actions

Enhance monitoring rules and security tools:

- Configure the email gateway to automatically quarantine *all* inbound `.exe` files, as well as files utilizing double-extension tactics (e.g., `*.doc.js`, `*.pdf.exe`).
- Create a SIEM alert for any internal endpoint attempting to connect to the subnets associated with the C2 IP (`198.51.100.88`).
- Implement application whitelisting to prevent unauthorized executables from running in the user space (e.g., `AppData` or `Downloads` folders).

Conduct regular phishing awareness training for staff:

- Deploy a targeted phishing simulation mimicking this exact scenario (urgency + disguised attachments) to the entire organization.
- Require mandatory refresher training on identifying sender anomalies and inspecting file extensions before opening attachment